

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

Week 4 | Cybersecurity | Networkwalks

Pentester Name (Cybersecurity Intern)	Aysan Aliguliyeva
Program / Batch	B082 - Networkwalks
Report Date	9 September 2026
Assessment Type	Authorized Black-Box Penetration Test
Client / Target	Mediroza General Hospital - https://medirozahospital.com
Authorization	Written permission granted for the controlled training environment
Scope	Web application reconnaissance, authentication assessment, patient-report exposure review, document-password security assessment, legacy-resource review, sensitive-data exposure analysis, risk evaluation, and remediation guidance.

1. Liability and Authorization Statement

This report documents cybersecurity testing conducted exclusively within the authorized Mediroza General Hospital training environment. The engagement was defined as a controlled black-box assessment of the target web application. Testing was restricted to the approved target and excluded denial-of-service activity, social engineering, and testing of unrelated systems. The purpose of the project is educational: to identify security weaknesses, understand their possible impact, and document practical remediation measures. No technique described in this report should be applied to a system without explicit authorization from its owner.

2. Executive Summary

The Week 4 engagement followed a realistic penetration-testing workflow from initial reconnaissance through impact analysis and reporting. The supplied evidence confirms four important stages: the public Mediroza web presence, the existence of a dedicated patient login portal, discovery of sensitive paths in robots.txt, and access to a patient-report area containing three encrypted pathology reports. These observations establish a clear attack surface around authentication, protected medical documents, and legacy application resources.

The project plan extends beyond discovery into controlled validation of authentication weaknesses, password-security testing of protected PDF files, review of legacy content, and analysis of possible confidential employee and shareholder information. Where no screenshot was supplied, this report records the assessment step in detailed narrative form rather than inserting artificial evidence. Exact patient data, recovered passwords, salary values, and shareholder records are intentionally not reproduced.

3. Scope, Rules and Methodology

Target: <https://medirozahospital.com>

Engagement model: Black-box web application penetration test in an authorized educational environment.

Primary objectives: Identify exposed application entry points, assess authentication and access controls, review protected patient documents, evaluate document password strength, investigate legacy resources, determine whether sensitive organizational information is exposed, and produce actionable remediation guidance.

Rules of engagement: Testing remains limited to the approved domain. No denial of service, social engineering, destructive modification, or out-of-scope testing is included.

Evidence policy used in this report: Only screenshots supplied by the pentester are embedded as visual evidence. Other project stages are documented textually and are not represented with substitute or fabricated screenshots.

4. Tools and Techniques

Tool / Technique	Purpose in the Assessment
Web browser / Firefox	Manual navigation, authentication review, portal validation, and inspection of web-accessible resources.
robots.txt review	Passive discovery of paths intentionally excluded from search-engine crawling but still visible to users.
Gobuster / directory enumeration	Structured discovery of directories and files when validating the external attack surface.
cURL	Direct HTTP request/response inspection and validation of web resources.
SQL injection testing	Authorized assessment of whether authentication inputs are handled safely by the back-end application.
pdf2john / hash extraction	Preparation of encrypted PDF material for password-strength testing in the lab.
John the Ripper / dictionary testing	Authorized recovery testing against weak or predictable document passwords.
Networkwalks Hash Calculator / Password Cracker	Alternative lab tools for PDF hash extraction and dictionary-based password assessment.
Text / database analysis utilities	Review of retrieved legacy backup material for sensitive data exposure without altering the original evidence.

5. Activities Performed and Technical Assessment

The assessment was documented as a sequence of linked activities. Each stage was intended to answer a specific security question and to show how one weakness can increase the impact of another. The sections below present the work in chronological order so the report reads as a continuous assessment rather than a set of isolated screenshots.

5.1 Initial Reconnaissance and Application Mapping

Objective: Establish the visible attack surface and identify user-facing functions before attempting any deeper testing.

The public Mediroza General Hospital website was reviewed first. The landing page exposed standard navigation options such as Home, About, Doctors, Contact, Staff Login and Patient Portal. The presence of a dedicated patient-facing authentication area was important because it represented a high-value entry point: successful compromise of authentication could affect access to confidential medical information. The reconnaissance stage therefore focused on identifying where the portal was located, how users reached it, and what additional paths might exist outside the main navigation.

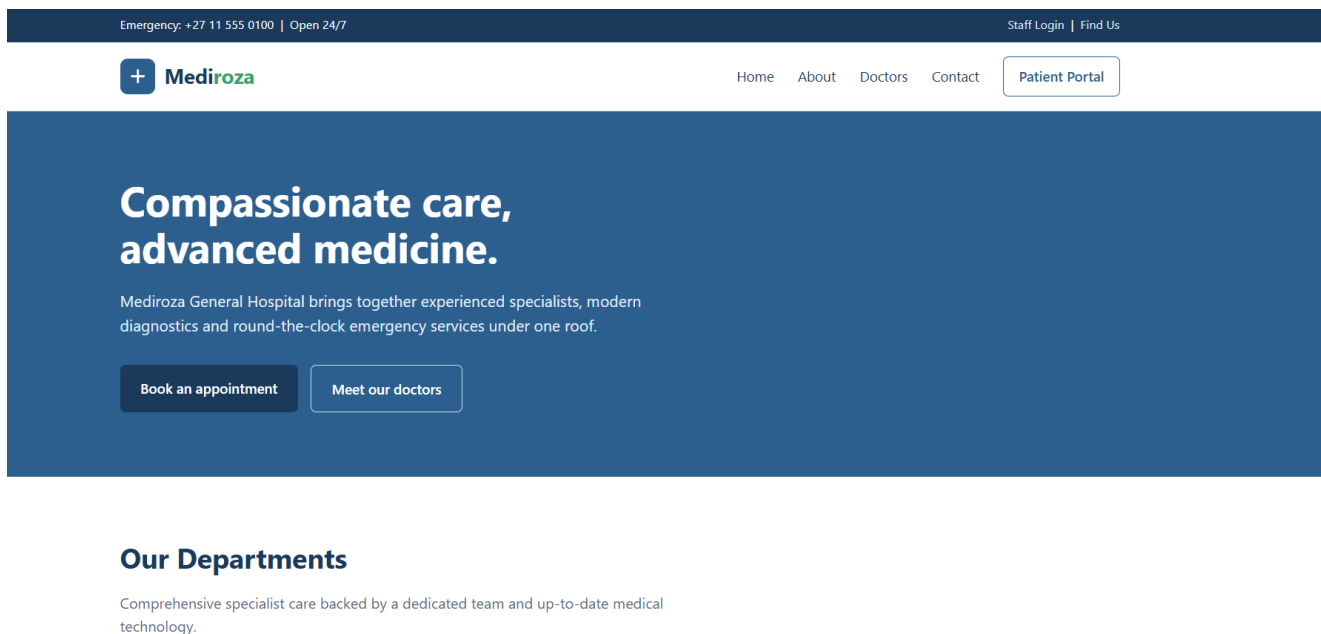


Figure 1 - Public Mediroza General Hospital landing page observed during initial reconnaissance.

5.2 Patient Portal Authentication Surface

Objective: Assess the login interface and determine whether the authentication workflow was sufficiently protected against manipulated input and unauthorized access.

The Patient Portal presented a conventional username-and-password form with a Sign in action and an optional show-password control. From a penetration-testing perspective, this interface became the primary authentication test point. Input handling, error behavior, session creation, and access-control enforcement are all relevant to this stage because weak validation can permit an attacker to bypass intended authentication logic.

The authorized project workflow included controlled SQL injection validation against the login mechanism. The assessment principle was to determine whether user-supplied values could alter the intended database query. A secure implementation should treat input strictly as data, use parameterized queries, and reject authentication when valid credentials are not supplied. Any ability to reach protected content without

legitimate credentials would represent an authentication-control failure with potentially serious privacy consequences.

Figure 2 - Patient Portal login interface selected for authentication-security assessment.

5.3 Public Discovery of Sensitive Paths through robots.txt

Objective: Review passive-discovery sources for paths that are not linked prominently from the public site.

The robots.txt file was inspected because it can reveal application areas that site operators do not want indexed by search engines. The file exposed three disallowed paths: /patient/, /staff/, and /old/, together with a sitemap reference. A robots.txt directive is not an access-control mechanism; it only asks compliant crawlers not to index a path. Therefore, sensitive directories listed there should still be protected by authentication and authorization controls.

The /patient/ and /staff/ entries confirmed the presence of role-specific application areas, while /old/ suggested legacy content that warranted careful follow-up. Legacy directories are security-relevant because forgotten backups, deprecated files, or previous application versions may contain information that is no longer intended for public access.

```
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 3 - robots.txt revealing /patient/, /staff/, and /old/ paths.

5.4 Access to the Patient Report Area

Objective: Determine whether protected medical-report resources could be reached after the authentication assessment.

The supplied evidence shows the patient-report area with three pathology reports available for download. The reports are identified by patient names and are marked as encrypted PDF documents. The page also states that report passwords are provided by the laboratory. This confirms that the application relies on two layers of protection: portal access control and document-level password protection.

From a security perspective, document encryption provides only limited protection if the surrounding application allows unauthorized access or if the document passwords are predictable. A successful portal compromise can expose the encrypted files themselves, after which an attacker can perform offline password testing without generating additional requests to the application. This substantially increases the importance of strong, unique document passwords and resilient authentication controls.

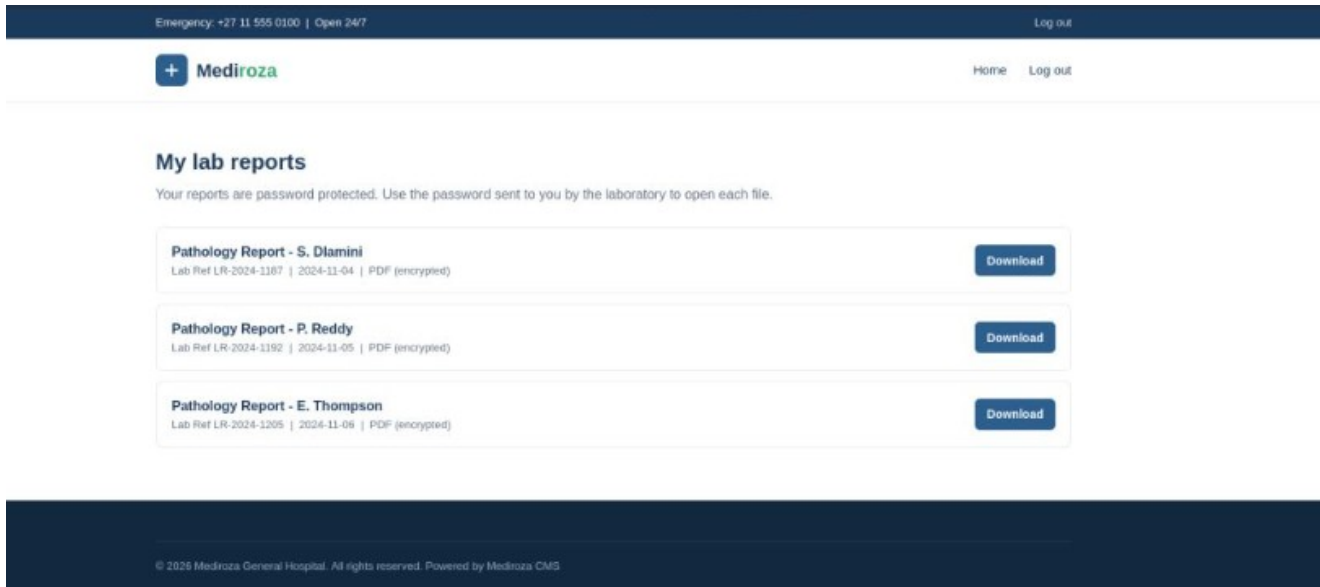


Figure 4 - Patient-report area showing three encrypted pathology PDF reports available for download.

5.5 Controlled Retrieval of Protected PDF Reports

Objective: Validate the practical impact of portal access by determining whether the encrypted pathology reports could be retrieved for authorized offline security testing.

The project workflow required the three identified reports to be downloaded into the controlled assessment environment. This step is significant because exposure changes from simple viewing of a page to acquisition of protected documents. Once a file is downloaded, the strength of its protection depends heavily on the cryptographic settings and the quality of its password. For this reason, the files should be handled as sensitive evidence and stored only in the project findings directory.

No additional screenshot is embedded for this stage because only the evidence supplied by the pentester is included in the report. The narrative nevertheless records the purpose of the activity and the security implications of document retrieval.

5.6 PDF Encryption and Hash Preparation

Objective: Assess whether the password protection applied to the retrieved reports could withstand common authorized password-recovery techniques.

Each protected PDF was treated as a separate security object. The assessment process first determines the document encryption format and extracts a password-verification hash using an appropriate utility such as pdf2john or an equivalent approved lab tool. The extracted value does not directly reveal the password; it provides a representation against which candidate passwords can be tested offline.

Keeping this stage offline is important for both accuracy and safety. It avoids repeated login attempts against the live application and demonstrates the real-world risk of weak document passwords after a protected file

has already been obtained. Exact hashes are not reproduced in this report because they form part of the sensitive project evidence.

5.7 Authorized Password-Recovery Assessment

Objective: Determine whether weak or predictable passwords could undermine the protection of the three pathology reports.

The extracted PDF hashes were subjected to dictionary-based password testing with approved tools such as John the Ripper or the Networkwalks Password Cracker. The three files were assessed individually because a password-recovery method that succeeds for one file may not succeed for another. Candidate testing is performed against the local hash representation rather than by repeatedly opening the web application.

A successful match would demonstrate that encryption alone is not an adequate compensating control when passwords are weak, reused, derived from predictable information, or selected from common wordlists. The security lesson from this stage is that password-protected medical documents require strong, unique secrets and preferably stronger access-control and secure-delivery mechanisms around the documents themselves. Specific recovered passwords are intentionally omitted from the report.

5.8 Verification of Decrypted Documents

Objective: Confirm that any successfully recovered password actually unlocks the corresponding protected document.

Password recovery is not considered fully validated until the recovered value successfully opens the intended PDF. In the project workflow, each recovered password would be tested against its corresponding report in the controlled environment. The contents are treated as confidential medical information and should not be duplicated unnecessarily in the final public-facing report.

This verification step demonstrates practical impact: if a weak password can be recovered and the report can be opened, the confidentiality provided by the document-level encryption has failed in a meaningful way. The report therefore records the impact without reproducing patient-sensitive content.

5.9 Legacy Resource Review - /old/

Objective: Investigate the legacy path identified during reconnaissance and determine whether outdated or backup resources were exposed.

The /old/ path discovered in robots.txt was prioritized for follow-up because legacy directories frequently contain obsolete application components, archived files, or backup material. Such content may remain accessible even after it is no longer referenced by the active site. A secure production environment should remove unnecessary legacy resources from the web root or enforce strict access controls.

The Week 4 project scenario specifically required analysis of previously retrieved material to identify a further critical exposure on the client server. Accordingly, the legacy-content stage focused on locating database-backup information and evaluating whether it contained confidential organizational records. This section is documented textually because no additional screenshot was supplied for the report.

5.10 Database Backup and Sensitive Information Exposure

Objective: Assess the confidentiality impact of any exposed database backup and determine whether it contains sensitive business or employee information.

Database backup files are high-value targets because they may contain a much broader data set than a normal application page. A single exposed backup can reveal user records, internal identifiers, historical data, credentials or password hashes, employee information, and corporate ownership details. For this reason, any web-accessible backup should be treated as a serious configuration failure even if the active application itself appears to enforce access controls correctly.

The project requirements call for identifying employee salary information and hospital shareholder details from the exposed material. In the final report, such values should be summarized rather than reproduced in full. The correct professional approach is to document the categories of sensitive information exposed, explain the business impact, retain detailed evidence privately for the authorized client or instructor, and redact personal or financial values from public copies.

5.11 Employee Salary Information Review

Security relevance: Salary records are confidential employment information and can expose both individuals and the organization to privacy, fraud, and social-engineering risks.

The assessment workflow included searching the recovered database material for employee-related records and salary fields. If salary information is present in a web-accessible backup, the issue is not simply that individual figures can be viewed; it demonstrates that internal human-resources data has escaped the intended trust boundary. Attackers could use such information for targeted phishing, impersonation, extortion, or reputational harm. The recommended reporting practice is to state that employee salary records were exposed while withholding names and exact monetary amounts from the public report.

5.12 Shareholder and Ownership Information Review

Security relevance: Corporate ownership information can be commercially sensitive and may support targeted fraud, impersonation, or business-intelligence activity.

The project also required examination of the recovered data for shareholder information. The assessment therefore considers whether ownership names, share allocations, contact information, or related corporate records are present in the exposed backup. As with employee information, full records should remain in protected project evidence rather than being copied into a public document. The finding is best expressed as a sensitive corporate data exposure caused by inadequate protection of legacy backup material.

6. Risk Analysis

Risk ratings below reflect the likely security significance of the Week 4 findings and assessment stages. They are written conservatively: the embedded screenshots prove discovery and access observations, while later impact stages are documented according to the authorized project workflow without adding fabricated visual evidence.

#	Finding	Risk	Impact / Justification
1	Patient authentication weakness / potential SQL injection	High	Weak input handling at a patient login can allow authentication bypass and expose protected medical resources.
2	Protected patient reports reachable after portal access	High	Unauthorized portal access can expose confidential report files and enable offline attacks against document passwords.
3	Sensitive paths disclosed in robots.txt	Low	The file reveals /patient/, /staff/, and /old/ paths and assists reconnaissance, though it does not itself bypass access control.
4	Weak PDF password protection	High	Predictable or recoverable document passwords can defeat encryption after the

			files are obtained.
5	Legacy /old/ content exposed	High	Forgotten legacy resources may reveal backup files or obsolete components outside normal application controls.
6	Database backup accessible from web content	Critical	A database backup can expose large volumes of confidential application, employee, and corporate information at once.
7	Employee salary information exposure	High	Confidential HR information can enable targeted social engineering, privacy violations, and reputational damage.
8	Shareholder information exposure	High	Sensitive ownership information can create commercial, privacy, and targeted-fraud risks.

7. Recommendations and Remediation

Use parameterized database queries: All authentication and data-access queries should use prepared statements or parameterized APIs. User input must never be concatenated directly into SQL statements.

Strengthen authentication controls: Implement secure credential verification, generic error messages, rate limiting, secure session handling, and server-side authorization checks for every protected resource.

Do not rely on robots.txt for protection: Sensitive paths should be protected by authentication and authorization. Remove unnecessary directory references and avoid exposing legacy locations publicly.

Remove or isolate legacy content: Delete obsolete directories from the production web root. If retention is required, move backups to non-web-accessible storage with restricted permissions.

Protect database backups: Backups should never be served through the web application. Encrypt them at rest, restrict access, apply retention policies, and monitor backup repositories.

Use strong document protection: Use long, unique, randomly generated passwords for protected files and avoid predictable lab, patient, date, or dictionary-based passwords.

Prefer secure document delivery: Where possible, rely on authenticated portal authorization and protected server-side storage instead of distributing long-lived encrypted documents that can be attacked offline.

Minimize sensitive data exposure: Store only necessary employee and shareholder data, apply least privilege, and redact or tokenize highly sensitive fields where operationally feasible.

Centralize logging and alerting: Monitor repeated authentication failures, abnormal file downloads, directory enumeration, and access to legacy or backup locations.

Perform periodic security reviews: Repeat authorized penetration tests after remediation and include regression testing for authentication, access control, backup exposure, and sensitive-file handling.

8. Evidence Register

The report intentionally embeds only the four screenshots supplied by the pentester. No substitute images were created for stages that did not have user-provided visual evidence.

- Figure 1 - Public Mediroza General Hospital landing page.
- Figure 2 - Patient Portal login interface.
- Figure 3 - robots.txt exposing /patient/, /staff/, and /old/.
- Figure 4 - Patient report area listing three encrypted pathology PDFs.

9. Conclusion

The Week 4 Mediroza project demonstrates how a black-box assessment progresses from simple reconnaissance to analysis of high-impact confidentiality risks. The public application exposes a patient portal, while robots.txt reveals role-specific and legacy paths that help map the application structure. The supplied portal evidence further shows three encrypted pathology reports available from the patient-report area, making authentication and document security central concerns.

The complete project workflow then evaluates whether authentication can be bypassed through unsafe input handling, whether protected PDFs can withstand offline password testing, and whether legacy server resources expose database backups containing confidential employee or shareholder information. These stages highlight an important penetration-testing principle: a seemingly small weakness can become far more serious when combined with weak access control, predictable document passwords, or poorly protected backup data.

The recommended remediation strategy is therefore layered. Mediroza should secure database queries, enforce authorization on every sensitive resource, remove legacy content from public reach, keep backups outside the web root, strengthen document-password practices, minimize sensitive-data exposure, and monitor for abnormal authentication and file-access activity. After remediation, a focused retest should confirm that the identified attack paths are no longer viable.

Author: Aysan Aliguliyeva | Cybersecurity Intern - B082 | Networkwalks Week 4 Project